

Seguridad física

Mikel Egaña Aranguren

mikel-egana-aranguren.github.io

mikel.egana@ehu.eus



Seguridad física

<https://doi.org/10.5281/zenodo.4302267>

<https://github.com/mikel-egana-aranguren/EHU-SGSSI-01>



Seguridad física

- Introducción
- Estándares
- SGSI (PDCA)
- Amenazas
- Google Data Center security

Introducción

Parte de la seguridad de la información que se centra en la protección de los activos físicos, incluidos los data centers, equipos de hardware y otros dispositivos críticos

Prevenir accesos no autorizados, daños y robos que puedan comprometer la integridad, disponibilidad y confidencialidad de los datos

Introducción

La seguridad física es tan importante como la lógica:

- Debe ser coherente con el valor de la información a proteger
- Las medidas de seguridad deben ser equilibradas
- Las medidas de seguridad deben aplicarse también a los servicios que ofrece la empresa

Estándares: EN 50600

European Norm for Data Centers: enfoque integral para el diseño, construcción y operación de data centers en Europa

Seguridad física, resiliencia, y sostenibilidad de la infraestructura

Estándares: ISO 27001

Estándar internacional para la gestión de la seguridad de la información

Controles de acceso físico, protección contra desastres naturales, y procedimientos para el mantenimiento de equipos

Estándares: ISO 27002

Cómo implementar los controles de seguridad definidos en ISO 27001

Seguridad de áreas y equipos, controles de acceso físico, y protección contra interrupciones ambientales

Estándares: ISO 27003

Describe los pasos a seguir para diseñar un SGSI

Como resultado de su aplicación se obtiene un plan de implementación del SGSI (Sistema de Gestión de Seguridad de la Información)

Estándares: ISO 27004

Evaluar la efectividad de un SGSI que ya esté implementado

Estándares: 27005

Identificación, evaluación y tratamiento de riesgos relacionados con la seguridad de la información

SGSI

Proceso PDCA (Plan-Do-Check-Act):

1. Planificar
2. Hacer
3. Comprobar
4. Actuar

Planificar (1)

Análisis pormenorizado de las áreas que componen nuestra organización que nos servirá para establecer una política de recuperación ante un desastre

Análisis de riesgos: plan de contingencia

- Se identifican las amenazas
- Se valoran las pérdidas si las amenazas se cumplen
- Se estima el coste de proteger la información

Planificar (1)

Plan de contingencia incorpora medidas:

- Técnicas
- Organizativas
- Humanas

Medidas Técnicas

Extintores contra incendios

Detectores de humo

Salidas de emergencia

Equipos informáticos de respaldo

Medidas Organizativas

Seguro de incendios

Precontrato de alquiler de equipos informáticos y ubicación alternativa

Procedimiento de backups

Procedimiento de actuación en caso de incendio

Medidas Humanas

Formación para actuar en caso de incendio

Designación de un responsable de sala

Asignación de roles y responsabilidades para la copia de seguridad

...

Planificar (1)

Plan de contingencia contiene subplanes:

- Respaldo
- Emergencia
- Recuperación

Planificar (1)

Plan de **Respaldo**:

- Qué hacer antes de que se produzca la amenaza
- Finalidad: prevenir la materialización de la amenaza
- Revisión de extintores, Simulacros de incendio, Realización de copias de seguridad (+ tests de recuperación), ...

Planificar (1)

Plan de **Emergencia**:

- Qué hacer mientras se produce la amenaza o justo después
- Finalidad: paliar los efectos adversos de la materialización de la amenaza
- Activación del precontrato de alquiler de equipos informáticos, Restauración de las copias de seguridad, ...

Planificar (1)

Plan de **Recuperación**:

- Qué hacer una vez controlada la amenaza
- Finalidad: restaurar las cosas al estado en el que se encontraban antes de la materialización de la amenaza
- Evaluación de daños, Traslado de datos desde la ubicación de emergencia a la habitual, Desactivación del precontrato de alquiler, Reclamaciones a la compañía de seguros, ...

Planificar (1)

El plan de **contingencia** no debe limitarse a enumerar una serie de medidas.

También debe incluir:

- Qué recursos materiales son necesarios
- Qué personas están implicadas en el cumplimiento del plan
- Cuáles son las responsabilidades concretas de esas personas y su rol dentro del plan
- Qué protocolos de actuación deben seguir y cómo son

Hacer (2)

Se implementan las contramedidas que se hayan estimado oportunas para proteger los bienes

Contramedidas de varios tipos: atenuar los riesgos, minimizar las pérdidas, asegurar una rápida recuperación

Fundamental: formación e información al personal afectado

Comprobar (3)

Revisiones periódicas (Auditorías)

Especialmente tras la materialización de una amenaza

Asegura:

- La puesta al día frente a nuevas amenazas
- El correcto funcionamiento del SGSI

Actuar (4)

Resultado de la comprobación

Amenaza prevista, contramedidas eficaces: revisar aspectos menores para mejorar la eficiencia

Amenaza prevista, contramedidas ineficaces: analizar causa de fallo y proponer nuevas contramedidas

Amenazas

Ocasionadas por los humanos

Ocasionadas por desastres naturales

Alteraciones del entorno

Acceso a información en soporte físico

Amenazas (Humanos)

Las instalaciones de procesamiento de información crítica o sensible deben estar en áreas protegidas con un perímetro de seguridad definido por:

- Vallas
- Controles de acceso apropiados

La protección debe ser proporcional a los riesgos identificados

Amenazas (Humanos)

Control de acceso a un área protegida: personal de seguridad, llaves, tarjetas de acceso, PIN , sistema biométrico, ...

Amenazas (Humanos)

Sistemas biométricos: sistemas que identifican a las personas en base a una característica “física”:

- Huella digital
- Palma de la mano
- Patrones oculares
- Reconocimiento facial
- Verificación de voz
- Pautas al caminar

Amenazas (Humanos)

Los visitantes de áreas protegidas deben ser supervisados o inspeccionados

La fecha y hora de sus entradas y salidas debe quedar registrada

El acceso debe permitirse con propósitos específicos y autorizados

El visitante debe ser instruido en las medidas de seguridad del área

Amenazas (Humanos)

Los accesos deben ser auditados de manera periódica

La información de los accesos también debe ser protegida

Es recomendable llevar una identificación visible de manera continua

Alentar a los empleados a sospechar de personas no identificadas

Amenazas (Humanos)

No todos los empleados tienen porqué saber qué se hace en el área protegida

Las áreas protegidas desocupadas deben quedar bloqueadas

No se debe permitir el acceso a cámaras fotográficas, móviles, etc.

Amenazas (Humanos)

[Inicio](#) / [Política](#)

Fotos del príncipe Guillermo como piloto revelan información clasificada

EFE - Londres

20/11/2012 - 20:13h

Me gusta

0

Twitter

1



La web de los duques de Cambridge de Inglaterra tuvo que retirar hoy unas fotos del príncipe Guillermo como piloto militar después de que el Ministerio de Defensa británico advirtiera de que mostraban información clasificada.

Las imágenes se publicaron esta mañana en la web del príncipe Guillermo y la princesa Catalina, en un intento de mostrar el trabajo del nieto de Isabel II como capitán de la Real Fuerza Aérea Británica en la base de rescate de Anglesey (Gales).

Amenazas (Desastres naturales)

Terremotos, fuego, tormentas eléctricas, inundaciones

Hay que contemplarlos en la política de seguridad de la empresa

Amenazas (Desastres naturales)

Pérdida de información

Pérdida de equipamiento

Tiempo en recuperarse = dinero

Resiliencia: capacidad de sobreponerse a una situación adversa

Amenazas (Desastres naturales)

¿Qué fue de las empresas que tenían su sede en la Torre Windsor (2005)?

En este edificio de oficinas se ubicaban principalmente empresas como la Consultora Deloitte (ocupando 20 de sus 32 plantas) o el Despacho de Abogados Garrigues

Amenazas (Desastres naturales)

Consultora Deloitte:

- Bien preparada
- El lunes siguiente trabajando en condiciones “normales”

Despacho de abogados Garrigues

- Copias de seguridad en otra planta del mismo edificio
- Perdieron grandes cantidades de información

Amenazas (Desastres naturales)

Consultora Deloitte:

Copias de seguridad externas de todos sus datos, y toda la información en documento físico tenía su copia en soporte informático

Amenazas (Desastres naturales)

Consultora Deloitte:

Estos backups se gestionan en localizaciones distintas a las de la propia empresa, cumpliendo así con las normativas de seguridad, con la Ley de Protección de Datos (LOPD) y con la autoprotección de las propias empresas

Amenazas (Desastres naturales)

Según el Disaster Recovery Institute International, el 90% de empresas que experimentan pérdidas significativas de datos, quiebran en un plazo de 3 años

Las medidas de contingencia ante desastres, la salvaguarda de datos, es una tarea imprescindible para que una empresa tenga continuidad en el desarrollo de su negocio

Amenazas (Desastres naturales)

Según un estudio de la Universidad de Texas, sólo el 6% de empresas con pérdida catastrófica de datos sobrevivirá, frente a un 43% que nunca reabrirá su negocio y un 51% que tendrá que cerrar en un plazo de 2 años

Amenazas (Desastres naturales)

Periodo máximo de inactividad que puede soportar una empresa sin poner en peligro su supervivencia es de:

- Sector seguros: 5,6 días
- Sector fabricación: 4,9 días
- Sector industrial: 4,8 días
- Sector distribución: 3,3 días
- Sector financiero: 2,0 días

Amenazas (Desastres naturales)

Terremotos:

- Probabilidad según la localización
- Pequeñas vibraciones pueden estropear maquinaria delicada
- Obras en el entorno pueden producir vibraciones
- Soluciones preventivas
- Soluciones arquitectónicas
- Emplazamientos adecuados
- Protecciones del edificio

Amenazas (Desastres naturales)

Fuego:

- Una mala instalación eléctrica
- Descuidos personales como puede ser fumar en sala de ordenadores
- Vulnerabilidades del sistema ante el humo

Amenazas (Desastres naturales)

Fuego (Soluciones preventivas):

- Detector humo y calor
- Materiales ignífugos
- Almacén de papel separado de máquinas
- Revisar el estado del falso suelo
- Extintores revisados

Amenazas (Desastres naturales)

Tormentas eléctricas:

- Subidas de tensión que afectan a los equipos
- Soluciones preventivas
- Limitadores de tensión
- Estabilizadores de corriente
- SAI (Sistema de Alimentación Ininterrumpida)

Amenazas (Desastres naturales)

Inundaciones y similares:

- Inundaciones por causas propias de la empresa
- Inundaciones por causas ajenas

Amenazas (Desastres naturales)

Inundaciones y similares (Soluciones preventivas):

- Instalar sistemas de drenaje de emergencia
- Concienciación de los empleados
- Revisar conductos del agua
- Localización del equipamiento
 - A nivel general (NO en un sótano al lado de un río)
 - A nivel del edificio (NO en una sala con grifos)

Amenazas (Desastres naturales)



Amenazas (Alteraciones del entorno)

- Temperaturas
- Polvo
- Insectos
- Soluciones preventivas
 - Sistemas de refrigeración
 - Limpieza
 - Cámaras acorazadas
 - Filtros en los conductos

Amenazas - Acceso a información en soporte físico

Cualquier dispositivo por el que se extraiga información confidencial debe encontrarse en un área de seguridad

- Nuevos dispositivos
- Permisos de impresión o extracción de datos sólo a los usuarios que realmente lo necesitan
- Imprimir sólo en presencia del usuario (tarjetas inteligentes)
- Revisión de los empleados al abandonar el área de seguridad

Google Data Center security

